

The background of the slide features a complex network diagram with numerous nodes and connecting lines, rendered in a light blue color against a dark blue background. The diagram is more prominent in the upper right and lower right areas, fading into the background towards the left.

Seguridad Cloud:
***Protección de Aplicaciones
Web con AWS WAF y AWS
Shield***

Sesión 6

Agenda

- 1.Introducción a la Seguridad de Aplicaciones Web.
- 2.Conceptos Fundamentales de WAF.
- 3.Configuración de AWS WAF.
- 4.Mitigación de ataques (SQLi, XSS, DDoS).
- 5.Escudo AWS: Protección contra DDoS.
- 6.Ejemplos prácticos y casos de uso.
- 7.Mejores Prácticas y Recomendaciones.



Introducción

¿Por qué son críticas las aplicaciones web?

- Exposición global en entornos cloud.
- Objetivo frecuente de ataques: datos sensibles, interrupción de servicios.

Comunas de Amenazas (Top 10 OWASP):

- Inyección SQL, XSS, Fuerza Bruta, Explotación de APIs.

Soluciones:

- **AWS WAF:** Filtro de tráfico HTTP/HTTPS malicioso.
- **AWS Shield:** Protección contra DDoS.



¿Qué es un WAF?

Definición:

- Firewall de Aplicaciones Web: Filtra, monitorea y bloquea tráfico malicioso en Capa 7 (HTTP/HTTPS).

Diferencias con Firewalls Tradicionales:

CARACTERISTICAS	CORTA FUEGOS TRADICIONAL	FUERZA AEREA DE LOS ESTADOS UNIDOS
Nivel de Operación	Capa 3/4 (Roja/Transporte)	Capa 7 (Aplicación)
Objetivo	IP, Puertos	Ataques SQLi, XSS, etc.

Estándares: Basado en OWASP para mitigar vulnerabilidades críticas.

Componentes de AWS WAF

- 1. **Reglas:** Defina condiciones para bloquear/permitir tráfico.
- 2. **Condiciones:** Parámetros (IPs, cadenas de texto, patrones).
- 3. **Grupos de Reglas:** Colecciones predefinidas (ej: OWASP Core Rule Set).
- 4. **ACL web:** reglas asociadas a recursos (CloudFront, ALB).

Ejemplo Visual:

[Diagrama: Flujo de tráfico a través de AWS WAF y Web ACL] AGREGAR

Configuración de AWS WAF

Pasos básicos:

1. Crear una **Web ACL** y asociarla a un recurso (ej: Balanceador de Carga).
2. Definir **reglas** :
 1. Bloquear IPs claves.
 2. Detectar patrones de SQLi/XSS en solicitudes.
3. Usar **Grupos de Reglas Predefinidos** (ej: OWASP).

Ejemplo práctico:

- Regla para bloquear solicitudes con el cuerpo.

"DROP TABLE"

Mitigación de ataques

1. Inyección SQL (SQLi):

•Ataque Ejemplo

```
1 SELECT * FROM users WHERE username='admin' AND password='password' OR '1'='1';
```

Solución WAF: Reglas que bloquean palabras clave (, ,).

UNION | SELECT : DROP

2. Secuencias de comandos entre sitios (XSS):

•Ataque Ejemplo: Inyección de .

```
<script>alert('XSS')</script>
```

•Solución WAF: Reglas OWASP para detectar scripts maliciosos.

AWS Shield - Protección contra DDoS

- **Tipos de AWS Shield:**
 - **Estándar Shield:** Protección básica gratuita (CloudFront, ELB).
 - **Escudo avanzado:**
 - Análisis en tiempo real.
 - Soporte 24/7 y reducción de costos por DDoS.
 - **Integración con WAF:**
 - Reglas automáticas basadas en detecciones de Shield.
-

Ejemplos prácticos

- **Caso 1: Bloqueo de IPs Maliciosas**

1. Crear regla en WAF con lista de IP sospechosas.
2. Asociar a Web ACL y verificar con herramientas (Postman).

- **Caso 2: Protección DDoS con Shield**

1. Habilitar Shield Standard en CloudFront.
2. Configurar alarmas en CloudWatch para monitorear tráfico anómalo.

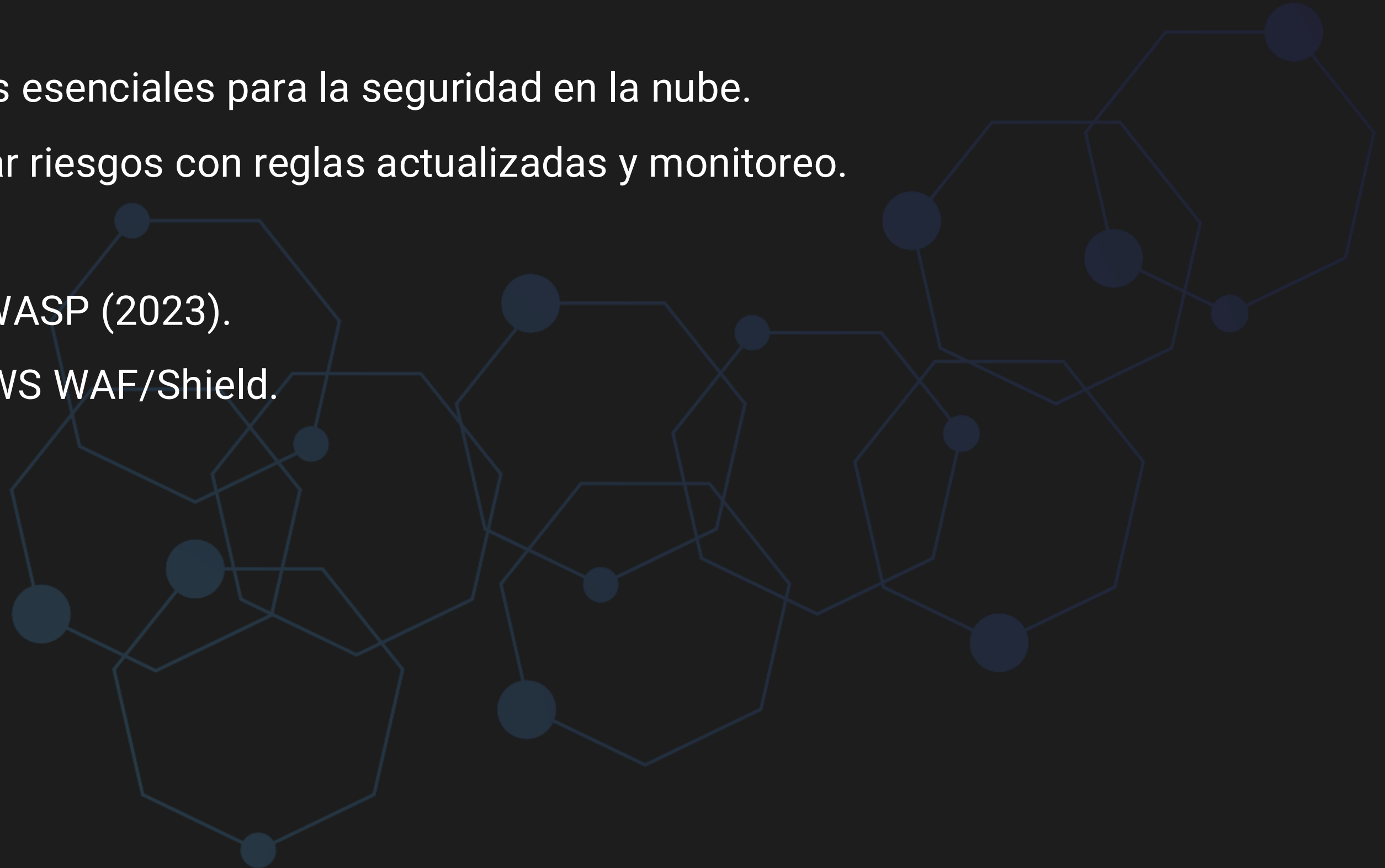


Buenas Prácticas

- 1.Actualización regular:** Mantener reglas alineadas con amenazas emergentes.
- 2.Pruebas Continuas:** Realizar pruebas de penetración.
- 3.Monitoreo Activo:** Usar CloudWatch para ajustar reglas.
- 4.Capas de seguridad:** Combinar WAF, Shield y buenas prácticas de codificación.

Conclusión

- **AWS WAF + Shield:** Capas esenciales para la seguridad en la nube.
- **Enfoque Proactivo:** Mitigar riesgos con reglas actualizadas y monitoreo.
- **Recursos adicionales:**
 - Los 10 mejores de OWASP (2023).
 - Documentación de AWS WAF/Shield.



Preguntas

1. ¿Cómo elegir entre Shield Standard y Advanced?
2. ¿Cómo probar reglas WAF sin afectar a los usuarios legítimos?



Material Complementario

- Guía rápida de configuración de WAF/Shield

- https://docs.aws.amazon.com/es_es/waf/latest/developerguide/getting-started.html

